

WAVESPARKS COMMUNITY

WaveSparks Community Admin 使用与运维手册

社区管理、平台治理与基础设施维护

适用角色: Admin

版本: 1.0

更新日期: 2026-07-29

目录

1. 管理员定位与完整生命周期	3
2. 上线前必须解决的已知风险	4
2.1 P0：全新生产库的首个 Admin 无法按现有脚本完成连接	4
2.2 P1：部分管理 Route Handler 仍按邮箱授权	4
2.3 P1：Preview Accounts API 不应存在于生产操作路径	5
2.4 P1/P2：尚未落地的控制	5
3. 权限与责任边界	5
4. 后台页面与职责	6
5. 成员与邀请全流程	6
5.1 单人邀请	6
5.2 批量导入	7
5.3 账号状态与安全动作	7
5.4 Mentor designation	8
6. Community 与 Event 生命周期	8
6.1 创建和发布 Event	9
6.2 Add to Main Community	9
7. 内容、Profile、Introduction 与 Matching 运营	9
7.1 Profile	9
7.2 内容审核	9
7.3 Introduction	9
7.4 Matching	10
8. 系统架构与权威来源	11
9. 环境变量管理	11
10. 发布与数据库迁移 Runbook	12
10.1 发布前	12
10.2 迁移	12
10.3 部署与验证	12
11. Vercel 使用与维护	13
11.1 当前用途	13
11.2 日常检查	13
11.3 环境变量与密钥轮换	13
11.4 回滚	13

12. Clerk 使用与维护	14
12.1 当前边界	14
12.2 初始配置	14
12.3 日常与故障处理	15
12.4 零停机轮换	15
13. Neon 使用与维护	15
13.1 当前边界	15
13.2 连接选择	16
13.3 迁移、分支与恢复	16
13.4 日常监控	16
13.5 凭据轮换	16
14. Resend 使用与维护	16
14.1 当前边界	16
14.2 域名与 API Key	17
14.3 日常检查与处置	17
14.4 零停机轮换	17
15. Vercel Blob 与媒体维护	18
16. 安全事件与离职 Runbook	18
16.1 成员账号异常	18
16.2 管理员离职	18
16.3 用户删除	18
17. 周期性维护清单	19
每日	19
每周	19
每月	19
每季度	19
18. 故障速查	20
19. 发布验收清单	20

版本：1.0 审计基线：2026-07-29 代码、当前界面与供应商官方文档 适用角色：WaveSparks Community 组织管理员、发布负责人和一线运维

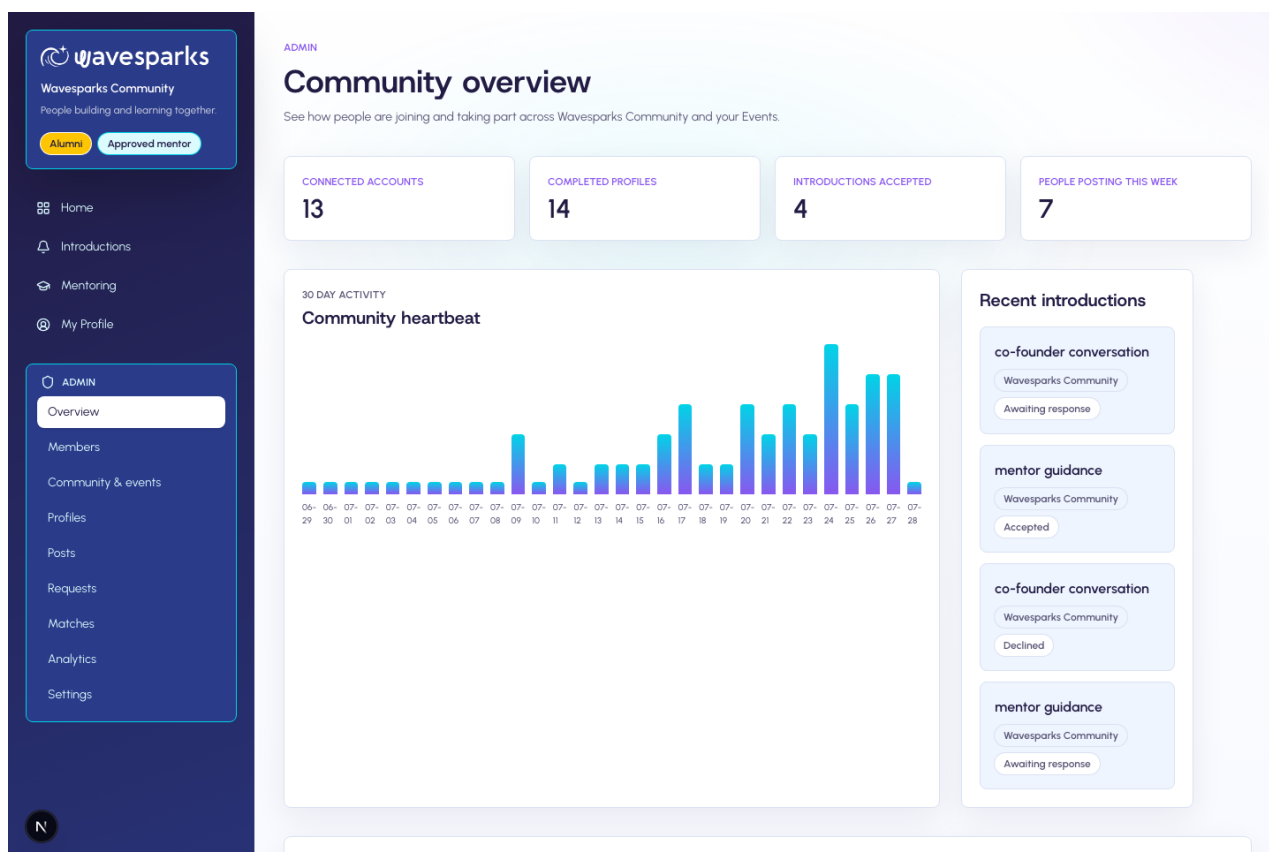
本手册区分“当前代码已经实现”“供应商控制台操作”和“发布前必须修复/补建”。执行生产变更前先确认目标环境、恢复点和授权人，绝不在工单、聊天或截图中粘贴密钥。

1. 管理员定位与完整生命周期

Admin 负责社区账户、Space、内容、介绍、匹配和日常运营；Vercel、Clerk、Neon、Resend 分别承载部署、身份、数据和产品邮件。

标准运营生命周期：

1. 解决首个 Admin 身份连接阻断，建立可审计的生产管理员。
2. 配置生产域名、环境变量、Clerk Webhook、Neon 数据库、Resend 域名和 Vercel Blob。
3. 运行环境审计、迁移、数据审计、测试和部署验证。
4. 设置社区名称、Logo、说明和邀请指引。
5. 创建 Event，设置生命周期、时间、参与者和 Matching。
6. 单人邀请或批量导入成员，并跟进邀请接受。
7. 独立管理角色、Mentor designation、账号状态和各 Space 权限。
8. 运营 Profile、帖子、Introduction、Matching 和 Analytics。
9. 处理账号停用、内容审核、安全事件和数据匿名化。
10. 每日检查部署、Cron、邮件和 Webhook；定期轮换密钥、恢复演练和容量复盘。



Admin Overview

2. 上线前必须解决的已知风险

以下不是可忽略的文档备注，而是当前代码审计确认的生产风险。

2.1 P0：全新生产库的首个 Admin 无法按现有脚本完成连接

`scripts/bootstrap-production.ts` 会创建 `org_admin` membership，但没有显式写入 `accountStatus`，因此采用 `invited` 默认值；脚本也不会创建本地一次性 Invitation、发送 Clerk Application Invitation 或写入 `clerkUserId`。

生产认证只按 Clerk User ID 连接本地身份，明确禁止按邮箱自动认领。因此全新库执行 `db:bootstrap` 后，首个 Admin 不能只靠同邮箱 Clerk 登录进入后台。

发布要求：

- 在代码中补齐正式的首管邀请/绑定方案，并增加自动化测试；
- 不得临时开启“按邮箱自动绑定”；
- 不得手工把数据库记录标成 `connected` 而不绑定 Clerk ID；
- 不得使用 Preview Accounts 作为生产管理员；
- 修复合入、迁移、演练并由第二人复核后，才能声明首管开通完成。

2.2 P1：部分管理 Route Handler 仍按邮箱授权

以下入口与 Clerk-ID 身份不变量不一致，发布前应统一改用服务端 Viewer Context/Clerk ID：

- Profile CSV 导出；
- 组织 Logo 上传；

- Member import 解析；
- 交互式 Matching recompute；
- Preview accounts provisioning。

Profile CSV 还应增加 Cache-Control: no-store 和导出审计。修复前应限制后台访问面、避免共享 Admin 账号，并在每次敏感操作后检查日志和数据结果。

2.3 P1：Preview Accounts API 不应存在于生产操作路径

POST /api/internal/preview-accounts 当前没有明确的 production/E2E guard，可写入四个 connected QA 账号，其中包含 Admin。它不是生产工具；发布前应禁用、移除或增加严格的非生产保护。

2.4 P1/P2：尚未落地的控制

- Schema 虽有 reports/admin_actions，但当前没有举报队列或中央 Admin Audit Log。
- App 内 Suspend 不会自动撤销 Clerk Session；凭据泄露时必须在 Clerk 另行处置。
- 没有 GitHub Actions 发布 Gate、Sentry/OTel、Log Drain 或代码化告警。
- Neon 恢复流程和演练记录未代码化；运行时与迁移共用数据库凭据。
- Resend 没有 Webhook、投递状态表或 Admin 重试界面。

手册后续提供人工控制流程，但不得把这些描述为已经自动化。

3. 权限与责任边界

Admin 入口要求账号 connected，并拥有 org_admin 或 platform_owner。当前没有“只管理成员”“只审核内容”等细粒度 Admin 角色，两者均是完整管理权限。

权限分为独立维度：

- Account permission：Member 或 Administrator；
- Mentor designation：notmentor、needsreview、approved；
- Account status：invited、connected、suspended、deprovisioned；
- Space entitlement：active、waitlist、rejected、suspended、removed；
- Space lifecycle：draft、upcoming、active、ended、archived。

Approved Mentor 不会自动获得 Admin。Admin 可以审计全部 Space，但如果要作为社交参与者出现在 People、发布内容、参与匹配或发起人工 Introduction，仍需显式加入对应 Space。

Admin 不能撤销自己的有效 Admin 权限；修改其他管理员时必须二次确认。建议始终保留两个独立、受 MFA 保护的管理员，避免单点失联。

4. 后台页面与职责

页面	主要能力	关键注意事项
Overview	Connected accounts、完整 Profile、已接受 Introduction、本周发帖人数、近期活动	是运营摘要，不是监报告警
Members	单人邀请、CSV/XLSX 导入、邀请重试/撤销、角色、Mentor、账号与 Space 状态	四个权限维度必须分别判断
Community & events	Main Community、Event 创建/更新/归档/恢复、Participants、Content、Matching	ended 仍可互动，archived 才停止访问
Profiles	查看完整资料与联系方式、Featured/Stale、CSV 导出	敏感数据；当前缺少中央导出审计
Posts	Hide/Unhide、Feature、Lock comments、Archive、图片/链接/评论审核	当前无用户举报入口
Requests	按状态/来源/Space 审查，人工创建 Introduction	Admin 自己必须有来源 Space access
Matches	重算、匹配类型/方向/权重/最低分、匿名反馈和运行记录	配置变更后检查结果与反馈
Analytics	账号、Profile、Introduction、Teams formed、活动趋势	当前是基础快照，不是完整 BI
Settings	名称、Logo、Tagline、社区说明、邀请指引	Logo 为公开 Blob

5. 成员与邀请全流程

5.1 单人邀请

1. 打开 Members → Invite people → One person。
2. 输入准确邮箱和可选姓名。
3. 选择 Member 或 Administrator。
4. 独立选择 Not a mentor 或 Approved mentor；邀请时不能制造 needs_review。
5. Member 必须选择目标 Main Community/Event 及初始 Space access。
6. Administrator 可不选 Space；只有需要参与社交时才添加。
7. 提交后检查行级 Invitation 状态，不把“Clerk 接受发送请求”当作送达证明。

WaveSparks 先创建本地一次性邀请，只把 token 哈希保存到 Neon，再让 Clerk 发送 Application Invitation。Clerk 只建立/登录身份，不创建 Clerk Organization、角色或社区权限。用户必须在 7 天内用匹配且已验证的邮箱接受。

邀请状态：

- pending：可用，等待接受；
- accepted：本地身份连接完成；
- revoked：已撤销；
- expired：超过有效期；
- failed：本地或 Clerk 发送失败。

重发会生成新的有效票据；撤销后旧链接不可再用。邀请邮件问题查 Clerk，不查 Resend。

5.2 批量导入

支持 .csv、.xlsx 或粘贴 CSV：

1. 上传或粘贴数据。
2. 映射必需 Email 和可选 Name。
3. 选择唯一目标 Space 与初始 access。
4. 在 Preview 中修正/移除问题行。
5. 确认 Invite N people。
6. 查看逐行结果，只重试 failed 行。

限制：2MB、首个工作表、最多 20 列、100 个非空数据行。选择文件不会发送邀请；文件只在内存解析，不保留。批量导入固定创建 Member + Not a mentor，不能批量授予 Admin 或 Mentor approval。

现有 Profile 和全局角色不会被覆盖。导入只在安全时增加目标 Space entitlement。重复邮箱首条生效；无效行不阻塞有效行。

The screenshot displays the 'Members' management interface in the WaveSparks Community Admin. On the left is a dark sidebar with the WaveSparks logo and navigation links: Home, Introductions, Mentoring, My Profile, and an ADMIN section containing Overview, Members (highlighted), Community & events, Profiles, Posts, Requests, Matches, Analytics, and Settings. The main area is titled 'Members' under 'ADMIN · MEMBER MANAGEMENT'. It features a search bar and several filter dropdowns: 'Name or email' (with a search input), 'Account status' (set to 'All account states'), 'Invitation' (set to 'All invitation states'), 'Mentor designation' (set to 'All mentor designations'), and 'Community or Event' (set to 'Wavesparks Comm'). A 'Filter' button and a 'Reset' link are also present. Below the filters, it states '14 members' and provides a note: 'Account permissions, mentor designation, and community or Event access are tracked separately.' Two member cards are shown. The first card for 'Priya' (Mentor review) shows email 'priya@example.com', 'Invited outsider offering brand and storytelling mentorship', 'ACCOUNT STATUS' as 'Active', and 'INVITATION' as 'Connected'. The second card for 'Tom' (Approved mentor) shows email 'tom@example.com', 'Founder-operator with logistics scars and strong B2B instincts', 'ACCOUNT STATUS' as 'Active', and 'COMMUNITY & EVENT ACCESS' as 'Wavesparks Community - Active'. Both cards have a 'Manage member' button at the bottom.

Members 管理

5.3 账号状态与安全动作

- invited：身份未连接，不能进入任何 Space。
- connected：可按各 Space entitlement 使用。
- suspended：可逆的全局安全阻断，覆盖所有 Space。
- deprovisioned：组织不再配置该账号，所有 Space 阻断。

只影响某个 Event 时使用 Space-level suspended/removed；涉及凭据泄露、严重违规或全局离职时使用 Account suspend/deprovision。

安全事件中，App suspend 只阻止应用授权，不撤销现有 Clerk Session。必须同时在 Clerk 撤销 Session/封锁身份，并根据情况轮换密钥。

5.4 Mentor designation

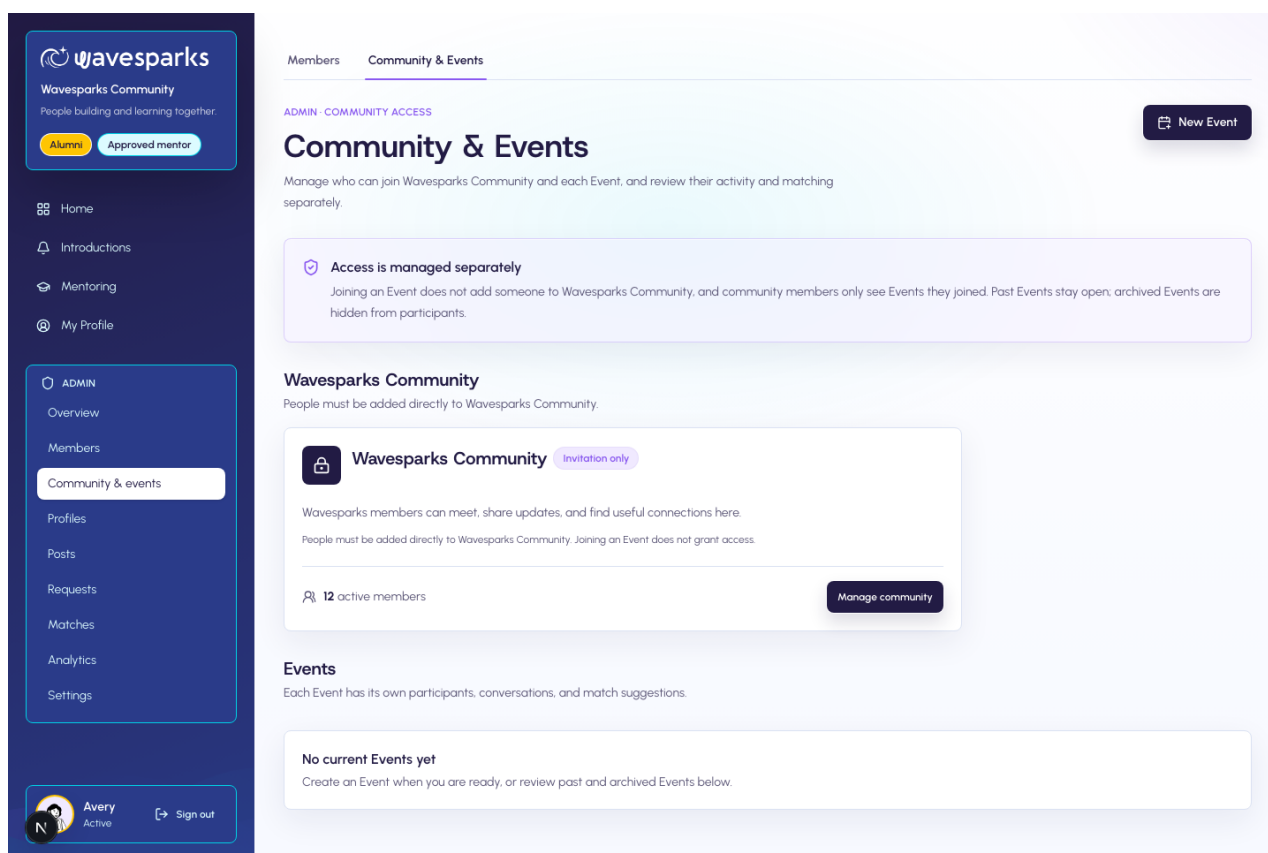
Mentor designation 是服务资格，不是管理权限。Needs review 用于待核验遗留信号；Approve 后才进入 Mentor 发现和匹配。Revoke 会让 pending Mentoring request 过期并停止新 Mentor discovery/matching，但保留私有 Mentor Profile 和 accepted/declined 历史。

6. Community 与 Event 生命周期

每个组织恰好有一个 Main Community，可有多个 Event。Main 永久、邀请制、始终 active，不能 ended 或 archived。

Event 状态：

- draft：仅 Admin 设置，参与者不可进入；
- upcoming：active 参与者可在开始前进入；
- active：正常读写和匹配；
- ended：显示 Past event，但当前仍可读写和匹配；
- archived：对参与者隐藏，访问与匹配停止，数据保留。



Community 与 Events

6.1 创建和发布 Event

1. 在 Community & events 新建 Event。
2. 填写名称、Slug、描述、标签、时间与 Matching 设置。
3. 保持 draft 完成内容和权限核对。
4. 通过单人邀请或 Event 内 Add participants 配置 roster。
5. 切换为 upcoming/active 后，用真实 Member 测试访问。
6. 活动结束后可先设 ended 保留互动；需要真正关闭访问时再 archive。

6.2 Add to Main Community

从 Event 选择合格参与者并 Add N to Main Community。该动作：

- 立即创建 active Main entitlement；
- 对已在 Main 的成员幂等；
- 保留原 Event 权限；
- 不复制帖子、关注、匹配、反馈或 Introduction；
- 对冲突逐行报告。

不得假设参加 Event 就自动加入 Main，也不得用数据复制模拟“升级”。

7. 内容、Profile、Introduction 与 Matching 运营

7.1 Profile

Profiles 可查看成员完整资料、运营联系方式、Featured/Stale 队列并导出 CSV。导出前确认目的、最小接收人和安全存储位置；下载后按组织保留策略删除本地副本。

当前导出缺少完整中央审计且部分授权逻辑需要修复。上线前修复后，再将其纳入定期运营。

7.2 内容审核

Posts 支持：

- Hide/Unhide；
- Feature/Unfeature；
- Lock/Unlock comments；
- Archive/Reopen；
- Remove/Restore 图片、链接预览和评论。

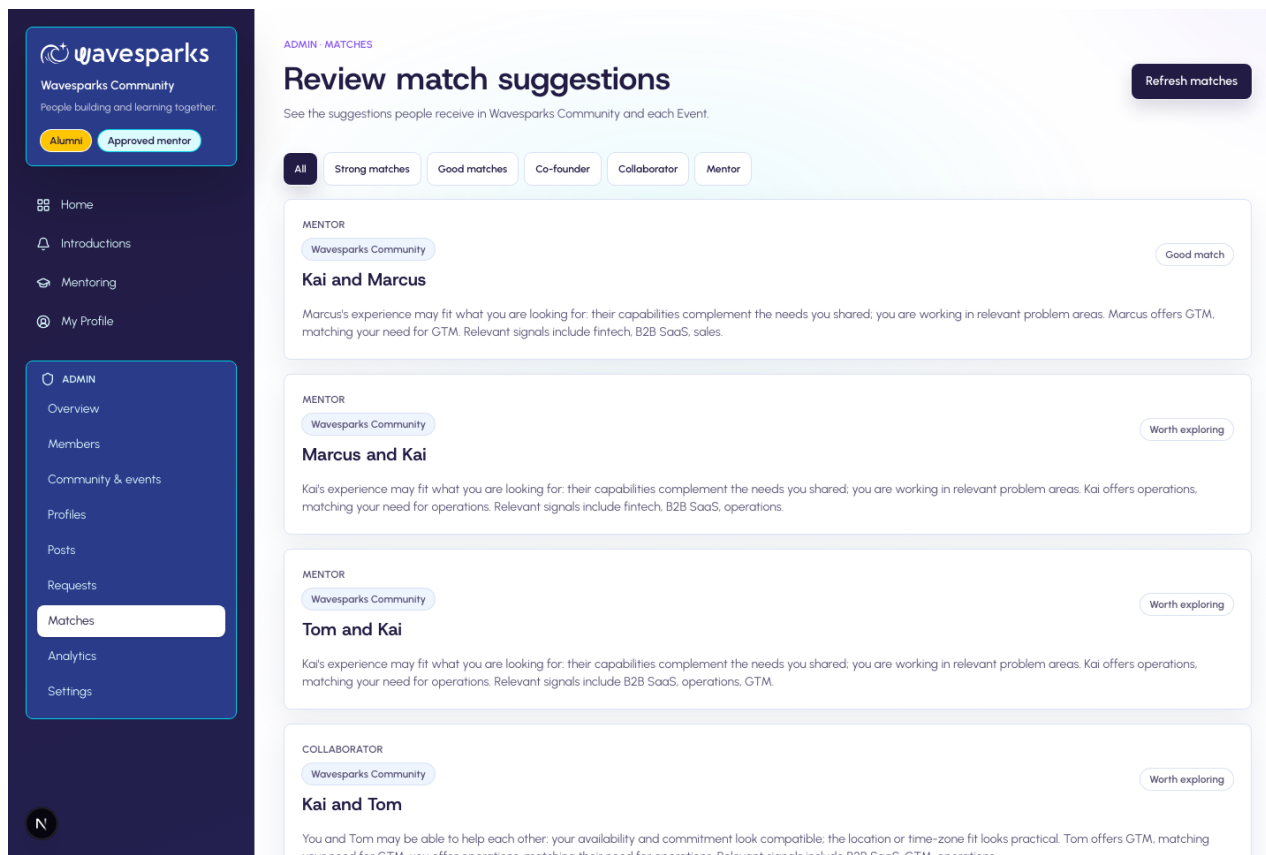
操作前记录 Post/Comment ID、Space、原因和处理人。当前没有可用的 Reports 队列和不可抵赖 Admin Audit Log，重要事件应在外部工单记录证据与决策。

7.3 Introduction

Requests 可按状态、来源和 Space 筛选。人工 Introduction 要求 Admin 本人有该 Space access；候选人需是当前有效、完成 Profile 的参与者。填写 Who is asking、Who should they meet、Purpose、Note 和 Suggested first message。

Admin 可查看联系方式，但不应绕过双方同意流程公开给第三方。Introduction 不授予新 Space 权限。

7.4 Matching



匹配管理

Matching 按 Space 运行。候选人必须 connected、Space active、Profile complete、Space intent complete 且 opt-in；ended Event 继续匹配，archived 停止。

后台可以：

- 查看 Strong/Good 和各 Match type；
- 创建/更新 Match type，最多 12 个启用项；
- 配置方向、最低分和六项权重，权重合计 100；
- 触发全量刷新；
- 查看匿名 Helpful/Not relevant 反馈及近期运行。

变更前记录当前配置，先在开发或隔离数据验证；生产刷新后抽查不同 Space、不同类型、Mentor gate、被隐藏和 dismissed 项。Fit index 是匹配程度，不是成功概率或声望。

8. 系统架构与权威来源

领域	权威系统	说明
代码与部署	GitHub + Vercel	当前无 GitHub Actions gate，主要依赖 Vercel Git 集成与人工检查
身份、凭证、Session、身份邀请	Clerk	不使用 Clerk Organizations
组织、角色、邀请授权、Space、内容、匹配	Neon/Postgres	应用授权唯一权威
普通产品邮件	Resend	Invitation 邮件不走 Resend
头像、Logo、帖子媒体	Vercel Blob	Avatar/Logo public；Post media private
语义 Embedding	OpenAI	text-embedding-3-large，1024 维；失败有本地确定性 fallback

应用部署区域在 `vercel.json` 固定为 `sin1`。应选择接近的 Neon 区域，但代码无法证明控制台实际区域。

9. 环境变量管理

变量	用途	生产要求
NEXT_PUBLIC_APP_URL	Canonical App URL 与邀请返回	HTTPS、社区应用域名，不是营销站
NEXT_PUBLIC_CLERK_PUBLISHABLE_KEY	Clerk 浏览器端	pk_live_
CLERK_SECRET_KEY	Clerk 服务端	Secret，不得公开
CLERK_JWT_KEY	Clerk JWT 验证辅助	按部署配置
CLERK_WEBHOOK_SIGNING_SECRET	Webhook 签名	whsec_
NEXT_PUBLIC_CLERK_*_URL	登录/注册路径	/org/wavesparks/... 或 HTTPS
DATABASE_URL	Neon Postgres	非 localhost；环境隔离
SPACE_SCOPED_READS_ENABLED	Space 隔离开关	必须明确为 true，否则 fail closed
OPENAI_API_KEY	Matching embeddings	Secret
RESEND_API_KEY	产品通知邮件	Domain-scoped Sending access
RESEND_FROM_EMAIL	发件人	已验证域名
CRON_SECRET	Cron Bearer auth	随机、建议至少 32 字符
BLOB_READ_WRITE_TOKEN	Vercel Blob	Secret；缺失时媒体上传不可用
WAVESPARK_ADMIN_EMAILS	Bootstrap 目标邮箱	当前首管流程有 P0，修复前不能视为可登录账号
E2E_CLERK_*	Clerk E2E 测试账号	不等同于本地 E2E bypass

生产不得设置 `E2E_LOCAL_AUTH_ENABLED` 或 `E2E_LOCAL_AUTH_SECRET`。开发、Preview、Production 必须分开配置 Clerk、Neon 和其他 Secret。

Vercel 环境变量变更只作用于后续 Deployment；修改后必须 Redeploy，再验证运行实例使用新值。不要在 Git、README、PDF、终端录屏或 PR 中写真实值。

10. 发布与数据库迁移 Runbook

10.1 发布前

1. 解决第 2 章 P0/P1 阻断，并通过代码审查。
2. 确认 Git 分支、目标 Vercel Project 和 Production Domain。
3. 在 Neon 建立可恢复时间点/分支，记录时间和负责人。
4. 检查 Vercel Production 环境变量完整且无 Preview/Dev 凭据。
5. 本地或受控 CI 运行：

BASH

```
pnpm install --frozen-lockfile
pnpm env:audit
pnpm readiness:prod -- --env-only
pnpm typecheck
pnpm lint
pnpm test
pnpm build
```

env:audit 要求开发库名为 wavespark_dev、开发使用 Clerk test keys、生产使用 live keys，并检查 Development/Production 不指向同一数据库。

10.2 迁移

先 dry run：

BASH

```
pnpm db:migrate -- --environment=production
```

确认输出的主机/数据库和恢复点，再由授权人执行：

BASH

```
pnpm db:migrate -- --environment=production --apply --confirm-production
pnpm readiness:prod
```

Migration 会创建 vector extension 并执行 Drizzle migrations。Production 写入必须同时带 --apply 和 --confirm-production。Readiness 全量检查还会审计每个组织恰好一个 Main Space、重复/孤儿关系和 Space-scoped 数据完整性。

10.3 部署与验证

1. 让 Vercel 创建 Preview Deployment。
2. 用隔离 Preview 数据验证登录、Space 边界和关键功能；Preview 不得连接 Production DATABASE_URL。
3. 部署/Promote Production。
4. 检查首页、Admin、真实 Clerk 登录、受邀用户接受流程。
5. 抽查 Feed、People、Profile、媒体、Introduction、Matching。
6. 在 Vercel Runtime Logs 检查 4xx/5xx、Webhook、邮件和 Blob 错误。

7. 检查两个 Cron 路径和最近状态。

应用回滚不会回滚 Neon schema。包含不兼容数据库变更时，采用向后兼容的扩展/迁移、先 Schema 后代码、验证后再删除旧字段；不要把 Vercel Rollback 当作数据库恢复。

11. Vercel 使用与维护

11.1 当前用途

- 托管 Next.js 16 应用，区域 sin1；
- 管理 Production/Preview/Development 环境变量；
- 执行 Cron；
- 提供 Runtime Logs/Observability；
- 承载 Vercel Blob。

Cron 使用 UTC：

- 0 8 * * * → /api/internal/matches/recompute，新加坡时间 16:00；
- 30 8 * * * → /api/internal/post-media/cleanup，新加坡时间 16:30。

两者使用 CRON_SECRET Bearer 校验，仅应在 Production 执行。

11.2 日常检查

- Deployments：Production 是否为预期 commit、构建是否成功；
- Runtime Logs：按 requestPath 检查 Cron、Webhook、邮件、Blob 和 5xx；
- Cron Jobs：最近调用 HTTP 状态、耗时和失败；
- Usage/Spend：Functions、Bandwidth、Blob 存储与请求；
- Alerts：建议启用 5xx、用量和 Spend Management；
- Observability：按保留要求配置 Log Drain；当前仓库没有持久化告警。

11.3 环境变量与密钥轮换

通用顺序：

1. 在第三方创建新 Secret/Key，保留旧值暂时有效。
2. 更新 Vercel 的正确 Environment scope。
3. Redeploy。
4. 用实际请求和日志确认新值生效。
5. 撤销旧值，再做一次验证。

不要只修改 Vercel 后等待旧实例自动更新。不要把敏感 Secret 放到 NEXT_PUBLIC_*

11.4 回滚

可在 Vercel 回滚/Promote 已知良好 Deployment，但必须：

- 检查该 Deployment 捕获的环境变量版本；
- 确认它兼容当前 Neon schema；

- 回滚后单独检查 Cron Jobs ；
- 记录事故时间、commit、影响与恢复结果。

官方资料：

- <https://vercel.com/docs/environment-variables>
- <https://vercel.com/docs/environment-variables/rotating-secrets>
- <https://vercel.com/docs/cron-jobs/manage-cron-jobs>
- <https://vercel.com/docs/logs/runtime>
- <https://vercel.com/docs/deployments/rollback-production-deployment>
- <https://vercel.com/docs/alerts>
- <https://vercel.com/docs/spend-management>
- <https://vercel.com/docs/regions>
- <https://vercel.com/docs/vercel-blob>

12. Clerk 使用与维护

12.1 当前边界

Clerk 管理 User、验证邮箱、凭证、Session 和 Application Invitation。WaveSparks 不使用 Clerk Organizations ；组织、角色、Membership 和 Space entitlement 全在 Neon。

普通邀请必须从 WaveSparks Admin 发起。直接在 Clerk Dashboard 创建 Invitation 只会创建身份，不会创建本地授权链。

Webhook endpoint：/api/webhooks/clerk，订阅：

- user.created ；
- user.updated ；
- user.deleted。

Webhook 验证签名并按 svix-id 去重。Created/Updated 只更新已绑定身份，Deleted 匿名化本地用户。Clerk Organization 事件不会授予权限。

12.2 初始配置

- Production 使用 Clerk live keys，与 Development test instance 分离；
- 配置 Production domain/DNS 和允许的 Redirect URL；
- 保持 Restricted sign-up，使注册只在有效邀请上下文开放；
- 创建公开 HTTPS Webhook endpoint，选择三个 User events；
- 把 Signing Secret 配到 Vercel Production 并 Redeploy；
- 用测试账号验证邀请、接受、update、delete 和失败重放；
- 本项目不应启用 Clerk Organization selection，保持应用自己的组织模型。

12.3 日常与故障处理

- 邀请未到：检查 Clerk Invitations、Application Logs、收件地址和邮件服务状态；
- 接受失败：核对邀请状态、7 天有效期、已验证邮箱、Clerk User ID 绑定；
- Webhook 失败：查看 Attempts、响应码和 Vercel 对应日志，修复后 Replay；
- 身份泄露：WaveSparks suspend + Clerk revoke sessions/block user；
- 删除未同步：确认 `user.deleted` 已投递且签名 Secret 正确，再检查本地匿名化。

Webhook 是异步、最终一致的。处理器必须保持幂等；不要把它当成用户请求内的即时事务。

12.4 零停机轮换

Clerk Secret Key：

1. 创建第二把有效 Key。
2. 更新 Vercel Production 并 Redeploy。
3. 从 Clerk last-used/Application Logs 和真实请求确认新 Key。
4. 删除旧 Key。

Webhook Secret：

1. 创建新的 Webhook endpoint/Secret。
2. 更新 Vercel 并 Redeploy。
3. 发送测试事件，验证签名和去重。
4. 删除旧 endpoint。

官方资料：

- <https://clerk.com/docs/guides/development/deployment/production>
- <https://clerk.com/docs/guides/secure/rotate-api-keys>
- <https://clerk.com/docs/guides/users/inviting>
- <https://clerk.com/docs/guides/secure/restricting-access>
- <https://clerk.com/docs/guides/development/webhooks/overview>
- <https://clerk.com/docs/guides/development/webhooks/syncing>
- <https://clerk.com/docs/guides/dashboard/logs/application-logs>
- <https://clerk.com/docs/guides/secure/session-options>

13. Neon 使用与维护

13.1 当前边界

代码只读取 `DATABASE_URL`。常规查询使用 Neon HTTP driver；事务和迁移使用 `postgres-js` 单连接。Migration 需要 `vector extension`。

运行时与 Migration 当前共用一个数据库凭据，没有最小权限角色拆分。仓库没有 Neon Branch、Snapshot、恢复或告警自动化。

13.2 连接选择

Serverless 运行时优先使用带 `-pooler` 的 pooled endpoint，减少并发连接压力；迁移、`pg_dump` 或需要直接连接语义的工具使用 direct endpoint。变更前核对 Neon 官方建议和项目连接模式。

13.3 迁移、分支与恢复

- 每次 Production migration 前创建 Point-in-time branch/snapshot，并记录恢复点；
- 在隔离 Branch 验证 Schema diff、Migration 和应用兼容性；
- 每季度在隔离 Branch 做恢复演练，记录 RTO/RPO；
- 按套餐配置 Restore window，重要 Production branch 可启用保护和 Scheduled snapshots；
- Preview database 必须隔离，绝不能复用 Production `DATABASE_URL`；
- Vercel 应用回滚不能替代 Neon PITR。

恢复时先冻结写入并记录时间点，在隔离 Branch 验证数据与应用，再决定切换连接或执行前滚修复。涉及不可逆数据变更时由数据库负责人和业务负责人共同批准。

13.4 日常监控

检查：

- CPU、RAM、数据库体积和 Compute 活跃时间；
- Client/Server connections 与 Pooler 指标；
- Cache hit、查询延迟、Deadlock 和错误；
- Branch/Storage 增长、Restore window；
- Vercel 与 Neon 区域延迟；
- Readiness 的 Space 数据完整性结果。

13.5 凭据轮换

优先创建新 Database role，复制必要 Grants，更新 Vercel、Redeploy 并验证，再撤销旧 Role。直接 Reset password 会立即使旧连接失效。当前运行时与迁移共用凭据；要真正实施最小权限拆分，需要代码和部署配置改造。

官方资料：

- <https://neon.com/docs/manage/projects>
- <https://neon.com/docs/guides/branching-intro>
- <https://neon.com/docs/connect/connection-pooling>
- <https://neon.com/docs/guides/schema-diff>
- <https://neon.com/docs/manage/endpoints/>
- <https://neon.com/docs/changelog>

14. Resend 使用与维护

14.1 当前边界

Resend 只发送普通产品通知，例如 Introduction requested/accepted/declined。成员邀请邮件由 Clerk 发送。

当前实现使用 Next `after()` 异步发送：

- 未配置时只记录 provider unconfigured，站内通知继续；
- 失败只写 Vercel console；
- 没有 Webhook、投递/退信/投诉状态表、出站审计或 Admin 重试入口；
- 底层支持 Idempotency key，但现有产品调用没有传入。

因此 Resend Dashboard/Logs 是当前邮件投递运维的主要依据。

14.2 域名与 API Key

- 推荐使用独立发送子域隔离信誉；
- 配置并验证 SPF、DKIM；
- 先用 DMARC `p=none` 观察，再按组织策略逐步收紧；
- API Key 使用 Domain-scoped Sending access，不授予 Full access；
- `RESEND_FROM_EMAIL` 必须属于已验证域名。

14.3 日常检查与处置

每日检查 failed、bounced、complained、suppressed 和最近发送量：

- Failed：结合 Vercel 日志定位配置、额度或收件地址；
- Bounced：修正地址后再发，避免重复硬退信；
- Complained：停止发送并检查同意依据；
- Suppressed：先解决根因，不要反复解除 suppression；
- 未收到 Invitation：转查 Clerk，不在 Resend 寻找。

如需要可审计投递，应新增 Resend Webhook：验证签名、按 `svix-id` 去重，容忍 at-least-once 和乱序投递，并存储最小必要状态。对可重试业务邮件应实际传入 Idempotency key；Resend 的去重窗口为 24 小时。

14.4 零停机轮换

1. 创建新的 Domain-scoped Sending Key。
2. 更新 Vercel Production 环境变量。
3. Redeploy 并发送受控测试通知。
4. 在 Resend Logs 按 Key/邮件验证。
5. 删除旧 Key，再确认发送成功。

官方资料：

- <https://resend.com/docs/dashboard/api-keys/introduction>
- <https://resend.com/docs/knowledge-base/how-to-handle-api-keys>
- <https://resend.com/docs/dashboard/domains/introduction>
- <https://resend.com/docs/dashboard/domains/dmarc>
- <https://resend.com/docs/dashboard/emails/introduction>

- <https://resend.com/docs/dashboard/emails/email-suppressions>
- <https://resend.com/docs/webhooks/introduction>
- <https://resend.com/docs/webhooks/verify-webhooks-requests>
- <https://resend.com/docs/dashboard/emails/idempotency-keys>

15. Vercel Blob 与媒体维护

- Avatar/Organization Logo 使用 public Blob URL，请勿上传敏感图像；
- Post 图片和链接预览使用 private Blob，经应用鉴权读取；
- 帖子最多 4 张图，每张 5MB，JPG/PNG/WebP；最长边处理到 2400px；
- `BLOB_READ_WRITE_TOKEN` 缺失时媒体上传不可用，文本功能仍可用；
- 每日清理 Cron 处理孤儿媒体，失败目前只留 Runtime Log。

每日检查 Blob 用量和 Cleanup Cron；内容下架要确认数据库 moderation 状态和 Blob 生命周期符合保留策略。轮换 Token 使用“新值 → Vercel → Redeploy → 上传/读取验证 → 撤销旧值”。

16. 安全事件与离职 Runbook

16.1 成员账号异常

1. 在 Members 全局 Suspend，记录原因。
2. 如果怀疑身份泄露，在 Clerk 撤销全部 Session/封锁用户。
3. 检查近期 Admin/Runtime/Application Logs；当前没有完整应用审计，需要结合外部工单。
4. 根据影响处理 Space、Invitation、内容和 Introduction。
5. 确认恢复条件后再分别解除 Clerk 与 App 侧限制。

16.2 管理员离职

1. 先确认至少另一名可登录管理员。
2. 在 WaveSparks 撤销其 Admin 或 deprovision。
3. 在 Clerk 撤销 Session/禁用身份。
4. 移除 GitHub、Vercel、Neon、Resend 和 Clerk 控制台权限。
5. 轮换其可能接触的 Secret，并检查最近 Deployment/Export/变更。
6. 在外部审计记录完成时间和复核人。

16.3 用户删除

Clerk `user.deleted` Webhook 成功后，本地资料和联系方式匿名化，账号停用，关注、收藏、匹配和通知等关联数据删除，pending Introduction 过期；历史帖子和评论保留为 Former member。

删除前告知数据保留规则。仅在 Clerk 删除而 Webhook 失败时，本地数据不会自动完成匿名化，必须修复并 Replay。

17. 周期性维护清单

每日

- Vercel Production Deployment、5xx 和 Runtime Logs ；
- 两个 Cron 的 HTTP 状态与路径日志 ；
- Clerk Invitation/Webhook failures ；
- Resend failed/bounced/complained/suppressed ；
- Neon 错误、连接和容量异常 ；
- Pending Invitation、Introduction 和内容运营队列。

每周

- 抽查 Space access 隔离、ended/archived 状态 ；
- 检查成员导入失败、Stale Profiles、Matching 运行与反馈 ；
- 检查 Blob/Functions/Database/Email 用量 ；
- 复核 Admin 和第三方控制台访问名单。

每月

- 运行 Production readiness 数据审计 ；
- 复核依赖更新、安全公告、告警与 Spend ；
- 测试受邀注册、Webhook、邮件、媒体和 Matching 核心路径 ；
- 清理不再需要的 Preview Deployment/Branch 和导出文件。

每季度

- Neon 隔离恢复演练 ；
- Clerk、Resend、Blob、Cron 等 Secret 轮换演练 ；
- Admin 离职与安全事件桌面演练 ；
- 复核 RTO/RPO、数据保留和供应商套餐限制。

18. 故障速查

症状	优先检查
Bootstrap Admin 无法登录	当前 P0 首管连接缺口；不要使用邮箱回退，先部署正式修复
Connected 用户只有 My Spaces	目标 Space 是否 active entitlement
Event 用户看不到 Main	正常；需显式 Add to Main
Ended Event 仍可发帖	当前设计；要停止访问请 Archive
Admin 不在 People/Matching	Admin 是否显式加入该 Space
用户能读不能互动	Profile 七项完成条件
无匹配	Profile、Space intent、opt-in、配置、候选数量、lifecycle
邀请未到	Clerk Invitation/Application Logs，不是 Resend
产品通知未到	站内通知、Resend Logs、Vercel Runtime Logs、目标 Space access
Webhook 不同步	Clerk Attempts/Replay、签名 Secret、Vercel 日志、幂等记录
媒体上传失败	Blob Token、大小/类型、用量和 Runtime Logs
Cron 失败	Vercel Cron、CRON_SECRET、requestPath 日志、数据库/OpenAI/Blob
App 回滚后仍报 DB 错	旧代码与当前 Neon schema 是否兼容；必要时 PITR/前滚修复

19. 发布验收清单

- 首个 Admin 通过正式邀请/绑定流程连接，P0 已由代码和测试关闭。
- 邮箱授权 Route Handler 和 Preview Accounts P1 已处理。
- Development/Preview/Production 的 Clerk、Neon、Resend 和 Blob 完全隔离。
- `SPACE_SCOPED_READS_ENABLED=true`，E2E bypass 未出现在生产。
- Environment audit、Production readiness、typecheck、lint、test、build 全部通过。
- Migration 前有可验证恢复点，Migration 后数据审计通过。
- Clerk live keys、Restricted sign-up、Redirect 和三个 User Webhook 正确。
- Resend 域名 SPF/DKIM 正常，发送 Key 最小权限。
- Vercel 两个 Cron、Runtime Logs、Alerts/Spend 配置核对。
- Event-only、Main-only、多 Event、Admin、Mentor、Suspended、Archived 场景通过。
- Feed、People、Posts、Notifications、Introductions、Matches 无跨 Space 泄漏。
- Vercel rollback 与 Neon restore 均完成独立演练。
- 管理员、控制台 Owner 和紧急联系人名单已双人复核。